# Lab 6 — Phishing Email Header Analysis (SPF / DKIM / DMARC)

You will dissect a raw email header to identify spoofing, then validate the sender domain's anti-spoofing DNS records.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

**Required software (free, apt):** - `dnsutils` - `swaks`

---

## Step 1 — Install lookup tools

```
apt update && apt install -y dnsutils swaks
```

---

## Step 2 — Save a sample header

Paste this *known-bad* header into `mail.eml`:

```
cat > mail.eml <<'EOF'
Return-Path: <attacker@evil.example>
Received: from mail.evil.example (1.2.3.4) by mx.victim.com
Authentication-Results: mx.victim.com;
```

```
 spf=fail (sender IP is 1.2.3.4) smtp.mailfrom=paypal.com;
 dkim=none;
 dmarc=fail action=quarantine header.from=paypal.com
From: "PayPal Security" <service@paypal.com>
To: bob@victim.com
Subject: Urgent: verify your account
EOF
cat mail.eml
```

Look at the three trust verdicts: **spf=fail**, **dkim=none**, **dmarc=fail**. All three say "this mail did not come from PayPal."

---

## Step 3 — Pull the real SPF record for the claimed sender

```
dig +short TXT paypal.com | grep spf
```

You will see a list of authorized sending IPs. `1.2.3.4` is **not** in that list — that is exactly why SPF failed.

---

## Step 4 — Pull DMARC policy

```
dig +short TXT _dmarc.paypal.com
```

`p=reject` means receivers should drop unauthenticated mail entirely.

---

## Step 5 — Pull DKIM selector

```
dig +short TXT s1024._domainkey.paypal.com
```

DKIM publishes the public key the receiver uses to verify the message body signature.

---

## Step 6 — Generate a test message with `swaks`

```
swaks --to test@example.com --from spoof@paypal.com \
      --server localhost --suppress-data --quit-after RCPT 2>&1 |
head
```

Use this safely against a local test server only — never against a third party.

---

## Free online tools

- **MXToolbox header analyzer** — https://mxtoolbox.com/EmailHeaders.aspx
- **Google Admin Toolbox Messageheader** — https://toolbox.googleapps.com/apps/messageheader/
- **DMARC analyzer (free)** — https://www.dmarcanalyzer.com
- **PhishTool** (free tier email triage) — https://www.phishtool.com
- **Have I Been Pwned (sender lookup)** — https://haveibeenpwned.com

---

## What you learned

- Where spoofing is exposed in email headers.
- The role of SPF (IP), DKIM (signature), and DMARC (policy).
- How to query DNS to check anti-spoofing posture for any domain.